Authly

Sistema de Gestión de Accesos

Especificación de casos de uso del MVP

Casos de uso en formato Fully Dressed, según el enfoque de Alistair Cockburn

Ingeniería de Software II — UCALP

1. Stack tecnológico

Authly se construye con las siguientes tecnologías:

- **Backend:** FastAPI (Python).
- **Base de datos:** PostgreSQL, gestionada a través de Supabase.
- **Frontend del panel:** HTML, CSS y JavaScript servidos por Nginx.
- **Autenticación:** JWT (JSON Web Tokens) con firma asimétrica.
- **Infraestructura:** Docker Compose para orquestar los servicios.

La arquitectura separa una capa de servicios compartida de dos grupos de endpoints: los routers de plataforma, que sirven al panel web del Administrador, y los routers de API externa, que consumen los Sistemas Externos en tiempo de ejecución.

2. Descripción del proyecto

Authly es una plataforma centralizada de autenticación y autorización. Ofrece dos superficies: un panel web donde los administradores de cada organización gestionan sus aplicaciones, roles y usuarios, y una API REST que los sistemas externos consumen en tiempo de ejecución para registrar y autenticar usuarios, validar tokens y verificar permisos.

Su objetivo es que los sistemas consumidores no implementen autenticación propia: se integran contra los endpoints estandarizados de Authly. Cada organización se registra con un CUIT único, y su administrador configura las aplicaciones que quiere proteger. Cada aplicación tiene sus propias credenciales (client ID y client secret), sus propios roles y permisos, y sus propios usuarios, independientes de las demás aplicaciones.

Este documento especifica los 11 casos de uso del producto mínimo viable (MVP), siguiendo el enfoque de Alistair Cockburn en *Writing Effective Use Cases*.

3. Actores

Actor	Tipo	Descripción	Casos
Administrador de Organización	Primario (persona)	Persona que registra su organización y, desde el panel web, gestiona sus aplicaciones, roles y usuarios. En el MVP hay un solo Administrador por organización.	01, 02, 03, 04, 06, 10
Sistema Externo	Primario (sistema)	Backend de una aplicación registrada en Authly. Consume la API para registrar y autenticar usuarios, obtener la clave pública y verificar permisos.	05, 07, 08, 09, 11
Servicio de correo	Secundario (sistema)	Servicio SMTP que entrega los códigos de verificación que Authly envía por correo electrónico.	01, 05, 10, 11
Usuario final	Interesado	Persona registrada en una aplicación. No interactúa con Authly de forma directa: lo hace a través del Sistema Externo.	05, 07, 09, 11
Equipo Authly	Interesado	Equipo que opera la plataforma y define sus políticas de seguridad. La superadministración de Authly queda fuera del MVP (AUPB-25 y 26).	Todos

4. Reglas de negocio y restricciones transversales

Cada regla indica su tipo (regla de negocio, restricción técnica o alcance) y los casos a los que aplica. Cada caso las cita en sus requisitos especiales.

AURN-01. Contraseña

Tipo: Regla de negocio. Aplica a: casos 01, 02, 05, 07, 10, 11.

- Mínimo 10 caracteres, con al menos una mayúscula, una minúscula, un número y un carácter especial.
- Nunca se almacena en texto plano.
- Al recuperarla, la contraseña nueva debe ser distinta de la actual.

AURN-02. Email

Tipo: Regla de negocio. Aplica a: casos 01, 02, 05, 06, 07, 10, 11.

- No distingue mayúsculas de minúsculas ni espacios al inicio o al final.
- Es único entre las cuentas de administrador, y único dentro de cada aplicación.
- Un mismo email puede ser administrador y usuario, y estar en varias aplicaciones, incluso de otras organizaciones.

AURN-03. Comparación de textos y datos con formato

Tipo: Regla de negocio. Aplica a: casos 01, 03, 04, 09.

- Los nombres de aplicación y de rol, los recursos y las acciones se comparan sin distinguir mayúsculas de minúsculas ni espacios sobrantes al inicio o al final. Recursos y acciones se guardan en minúsculas.
- El nombre de una aplicación es único dentro de la organización, y el de un rol lo es dentro de la aplicación.
- CUIT: 11 dígitos, con o sin guiones. Se guarda solo con dígitos y es único en la plataforma. La validación del dígito verificador es tentativa: no se realiza.

AURN-04. Código de verificación

Tipo: Regla de negocio. Aplica a: casos 01, 05, 10, 11.

- 6 dígitos, vence a los 10 minutos y admite un máximo de 5 intentos. Al agotarse los intentos o vencer, el proceso se reinicia.
- Solo consume intentos un código incorrecto. En los casos 10 y 11 el código se valida primero: los errores de la contraseña nueva (que no coincida, que no cumpla la complejidad o que sea igual a la actual) se informan solo si el código es válido, y no consumen intentos. Así la recuperación no sirve para probar contraseñas sin tener un código.
- Cada código pertenece a un propósito (registro o recuperación, de administrador o de usuario) y a un email, y a una aplicación en los de usuarios. Un código nuevo para el mismo conjunto invalida el anterior.
- Límite de emisión: como máximo 3 códigos por hora para el mismo email y propósito (y aplicación, en los de usuarios). Es un valor tentativo. Superado el límite, no se emite un código nuevo hasta que pase la hora. Junto con los 5 intentos por código, acota a 15 las pruebas de adivinación por hora sobre un millón de combinaciones. Consecuencia conocida: un tercero que conoce un email puede agotar su cupo, o pisar el código pendiente porque un código nuevo invalida el anterior, e impedir por una hora que esa persona se registre o recupere su contraseña. Riesgo aceptado para el MVP.
- Se envía por correo electrónico. Los correos a usuarios de aplicación indican el nombre de la aplicación.
- Mientras espera el código, Authly no conserva los datos del registro (nombre, apellido, contraseña, CUIT): solo el email, el código en forma hasheada, su vencimiento, el contador de intentos y las fechas de los códigos emitidos en la última hora. Criterio pendiente de confirmar con el profesor (consulta 1).

AURN-05. Política de mensajes

Tipo: Regla de negocio. Aplica a: casos 01, 02, 03, 04, 05, 07, 09, 10, 11.

- Genéricos, sin revelar si una cuenta existe: login del panel y de usuarios (casos 02 y 07), recuperación de contraseña, incluido el límite de códigos (casos 10 y 11), y credenciales de aplicación inválidas (casos 05, 07, 09 y 11), que no distinguen entre client ID y secret.
- Explícitos: registro (los casos 01 y 05 informan que un email o un CUIT ya está registrado y cuándo se superó el límite de códigos), nombres repetidos de aplicación y de rol (casos 03 y 04) y usuario inexistente en la consulta de permisos (caso 09), cuyo solicitante ya está autenticado.
- Criterio para casos nuevos: genérico cuando un solicitante sin autenticar podría averiguar qué cuentas existen, y explícito en los demás.
- Limitación: como el registro informa qué emails existen, la protección contra la enumeración de cuentas es parcial.

AURN-06. Sesiones y tokens

Tipo: Restricción técnica. Aplica a: casos 02, 06, 07, 08, 09, 10, 11.

- Los tokens los firma Authly y se verifican con la clave pública (AU-CU-08). La clave es única para toda la plataforma y no rota (AUPB-20).
- Duración de 8 horas (tentativo), fija y no configurable. Los tokens no se pueden revocar ni renovar (AUPB-04 y 05). Cerrar sesión consiste en descartar el token en el cliente.
- El token de administrador identifica al administrador y a su organización. El de usuario identifica al usuario y a su aplicación. Ninguno se acepta en lugar del otro.
- Contenido mínimo de todo token: identificador del sujeto (administrador o usuario), tipo de token (administrador o usuario), organización (en el de administrador) o aplicación (en el de usuario), y fechas de emisión y de vencimiento. Ningún token incluye permisos (AU-CU-09).
- Un token emitido antes de cambiar la contraseña o de eliminar al usuario sigue vigente hasta vencer (AUPB-18 y 23).

AURN-07. Transporte

Tipo: Restricción técnica. Aplica a: todos los casos.

- Todas las comunicaciones, del panel y de la API, viajan cifradas (HTTPS).

AURN-08. Credenciales de aplicación

Tipo: Restricción técnica. Aplica a: casos 03, 05, 07, 09, 11.

- Client ID: UUID público. Client secret: lo genera Authly, se guarda hasheado y se muestra solo al crear o regenerar.
- Toda solicitud de la API externa las incluye y las valida, salvo la de la clave pública (AU-CU-08). Ante un fallo, se rechaza sin distinguir la causa.

AURN-09. Aislamiento y poblaciones

Tipo: Regla de negocio. Aplica a: casos 03, 04, 05, 06, 07, 09, 11.

- Un Administrador solo gestiona aplicaciones, roles y usuarios de su organización.
- Las credenciales de una aplicación solo dan acceso a los usuarios de esa aplicación.
- Las cuentas de administrador y los usuarios son poblaciones separadas, y los usuarios son independientes por aplicación (identidad compartida: AUPB-14).

AURN-10. Registro operativo

Tipo: Restricción técnica. Aplica a: casos 01, 05, 08, 10, 11.

- Todo fallo de envío de correo (casos 01, 05, 10 y 11) o de obtención de la clave pública (caso 08) se registra para el equipo de Authly, se informe o no al solicitante.
- En los casos 08, 10 y 11 el solicitante recibe una respuesta genérica. En los casos 01 y 05 se le informa que no pudo enviarse el código.
- Es distinto del log de auditoría (AUPB-12).

AURN-11. Alcance del MVP

Tipo: Alcance. Aplica a: todos los casos.

- Fuera del MVP: invitar administradores (AUPB-01), bloqueo por fuerza bruta (AUPB-03), renovación y cierre de sesión con invalidación (AUPB-04 y 05), log de auditoría (AUPB-12), búsqueda de usuarios (AUPB-15), límite de aplicaciones (AUPB-10), límite de códigos por dirección IP (AUPB-06), superadministración y administración de organizaciones (AUPB-25 y 26).
- Sin límite en el MVP: aplicaciones, roles, permisos, registros, consultas y solicitudes de la API. Los códigos de verificación sí tienen un límite de emisión por email (AURN-04).
- Consecuencia: cada organización tiene un solo Administrador.

5. Lista de casos de uso

Orden	Caso	Nombre	Nivel	Justificación
1	**AU-CU-01**	Registrarse en la plataforma	Objetivo de usuario	Sin cuenta ni organización no existe nada.
2	**AU-CU-02**	Autenticarse en el panel	Subfunción	Sin sesión el Administrador no puede configurar.
3	**AU-CU-03**	Gestionar aplicaciones de la organización	Objetivo de usuario	Sin aplicación no hay credenciales, roles ni usuarios.
4	**AU-CU-04**	Gestionar roles y permisos de una aplicación	Objetivo de usuario	Sin rol por defecto no se pueden registrar usuarios.
5	**AU-CU-05**	Registrar usuario en una aplicación (vía API)	Objetivo de usuario	Sin usuarios no hay a quién autenticar ni autorizar.
6	**AU-CU-06**	Gestionar usuarios de una aplicación	Objetivo de usuario	Cambiar roles y eliminar usuarios. Habilita eliminar roles.

Orden	Caso	Nombre	Nivel	Justificación
7	**AU-CU-07**	Autenticar usuario de una aplicación (vía API)	Objetivo de usuario	Sin login no hay token.
8	**AU-CU-08**	Obtener la clave pública de validación (vía API)	Objetivo de usuario	Primera necesidad de runtime: validar tokens.
9	**AU-CU-09**	Verificar permiso de un usuario (vía API)	Objetivo de usuario	Segunda necesidad de runtime.
10	**AU-CU-10**	Recuperar la contraseña de un administrador	Subfunción	Con un solo Administrador por organización, un olvido deja a la organización sin acceso. Reutiliza el mecanismo del caso 01.
11	**AU-CU-11**	Recuperar la contraseña de un usuario de una aplicación (vía API)	Subfunción	Reutiliza el mecanismo del caso 05 y no bloquea el flujo.

6. Especificación de los casos de uso

Cada caso comienza en una página nueva. Los casos 03, 04 y 06 siguen el patrón «Gestionar X»: el escenario principal describe una operación y las demás se tratan como extensiones.

1. AU-CU-01: Registrarse en la plataforma

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Administrador de Organización
Actor secundario	Servicio de correo
Disparador	El Administrador decide registrarse en Authly.

Interesados e intereses

- **Administrador de Organización:** quiere obtener una cuenta en Authly y una organización para empezar a configurar sus aplicaciones.
- **Equipo Authly:** quiere que solo existan cuentas de administrador con datos válidos y emails verificados, y organizaciones con CUIT único.

Precondiciones

Ninguna.

Garantías mínimas

- No se crea ninguna cuenta ni organización si el registro no se completa.
- No existen dos cuentas de administrador con el mismo email ni dos organizaciones con el mismo CUIT.

Garantías de éxito

- Existe una cuenta de administrador con email verificado.
- Existe una organización nueva, con CUIT único.
- La cuenta queda asociada a esa organización como su administradora.

Escenario principal de éxito

N.°	Acción
1	El Administrador ingresa sus datos personales (nombre, apellido, email, contraseña y su confirmación) y los datos de su organización (nombre y CUIT).
2	El sistema valida que el email tenga formato válido y no esté registrado como cuenta de administrador, que las contraseñas coincidan, que la contraseña cumpla los requisitos de complejidad, y que el CUIT tenga formato válido y no esté registrado.
3	El sistema envía un código de verificación de 6 dígitos al email ingresado.
4	El Administrador ingresa el código recibido y confirma el registro.
5	El sistema repite las validaciones del paso 2 y valida el código.
6	El sistema crea la cuenta de administrador y la organización, y las asocia. El registro está completo.

Extensiones

2a. Los datos personales son inválidos (formato de email, contraseñas que no coinciden o contraseña que no cumple la complejidad):

2a.1. El sistema informa cada error y qué requisitos faltan.

2a.2. El Administrador corrige. Vuelve al paso 1.

2b. El email ya está registrado como cuenta de administrador:

2b.1. El sistema informa que el email ya está registrado.

2b.2. El Administrador ingresa otro email (vuelve al paso 1) o abandona (el caso termina sin éxito).

2c. El CUIT tiene formato inválido:

2c.1. El sistema informa que el formato no es válido.

2c.2. El Administrador corrige. Vuelve al paso 1.

2d. El CUIT ya existe en la plataforma:

2d.1. El sistema informa que ya existe una organización con ese CUIT.

2d.2. El Administrador corrige (vuelve al paso 1) o abandona (el caso termina sin éxito).

3a. No se pudo enviar el email:

3a.1. El sistema deja constancia para el equipo de Authly e informa que no pudo enviar el código.

3a.2. El Administrador corrige el email (vuelve al paso 1) o abandona (el caso termina sin éxito).

3b. Ya existía un código pendiente para ese email:

3b.1. El sistema invalida el código anterior y emite el nuevo. Continúa en el paso 4.

3c. Se alcanzó el límite de códigos para ese email (AURN-04):

3c.1. El sistema no envía ningún código e informa que se superó el límite y cuándo podrá pedir uno nuevo.

3c.2. El caso termina sin éxito.

5a. El código ingresado es incorrecto (incluye que el email con el que se confirma el registro sea distinto del que recibió el código):

5a.1. El sistema informa que el código es incorrecto e indica cuántos intentos restan.

5a.2. El Administrador reintenta. Vuelve al paso 4.

5b. El código es incorrecto y se agotaron los 5 intentos:

5b.1. El sistema invalida el código e informa que el registro debe reiniciarse.

5b.2. El caso termina sin éxito.

5c. El código expiró:

5c.1. El sistema informa que el código expiró y que el registro debe reiniciarse.

5c.2. El caso termina sin éxito.

5d. Alguna validación del paso 2 ya no se cumple al reenviar los datos (por ejemplo, otra solicitud registró el email o el CUIT mientras se esperaba el código):

5d.1. El sistema no crea nada y responde como en la extensión correspondiente (2a, 2b, 2c o 2d).

5d.2. El Administrador corrige (vuelve al paso 1) o abandona (el caso termina sin éxito). Al pasar de nuevo por el paso 3, recibe un código nuevo.

6a. El email o el CUIT fue registrado por otra solicitud entre la validación del paso 5 y la creación:

6a.1. El sistema no crea nada e informa qué dato ya no está disponible.

6a.2. El Administrador corrige. Vuelve al paso 1. Al pasar de nuevo por el paso 3, recibe un código nuevo.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-03 (Comparación de textos y datos con formato); AURN-04 (Código de verificación); AURN-05 (Política de mensajes); AURN-10 (Registro operativo); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- La creación de la cuenta y de la organización es atómica: se crean ambas o ninguna.
- El registro informa de forma explícita que un email o un CUIT ya está registrado (AURN-05).
- Mientras espera el código, Authly no conserva los datos del registro. El panel los conserva y los reenvía junto con el código, y el sistema repite las validaciones (AURN-04).

Variaciones de tecnología y datos

El código de verificación se envía por correo electrónico.

Frecuencia de ocurrencia

Baja. Una vez por cada nuevo administrador.

Cuestiones abiertas

- Validar con el profesor el criterio de no conservar los datos del registro mientras se espera el código (consulta 1).
- Confirmar si la validación del CUIT incluye el dígito verificador (tentativo: no se valida, AURN-03).
- El CUIT no se verifica contra ningún registro ni contra quien se registra. Alguien podría registrar el CUIT de otra organización y bloquearla. Sin administración de organizaciones (AUPB-26), solo el equipo de Authly puede corregirlo, a mano.
- El límite de códigos por email (AURN-04) acota el envío repetido a una misma dirección, pero permite que un tercero agote el cupo de un email ajeno y le impida registrarse durante una hora (riesgo aceptado). Tampoco impide enviar correos a muchas direcciones distintas (AUPB-06).

Product Backlog vinculado

- AUPB-01 Invitar a un administrador adicional
- AUPB-02 Reenvío de código sin reiniciar
- AUPB-06 Límite de códigos por IP y contra abuso
- AUPB-13 Datos adicionales de perfil y organización
- AUPB-26 Administrar organizaciones

Retirado o descartado en este caso:

- AUPB-02, limpieza de cuentas no verificadas: descartado, ya no existen cuentas inactivas.
- AUPB-03, validación de formato de teléfono: fusionado en el AUPB-13.
- AUPB-05, expiración de código: retirado, la expiración ya está en el MVP (extensión 5c) y el reenvío pasó al AUPB-02.

2. AU-CU-02: Autenticarse en el panel

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Subfunción
Actor principal	Administrador de Organización
Disparador	El Administrador necesita acceder al panel.

Interesados e intereses

- **Administrador de Organización:** quiere acceder al panel para gestionar sus aplicaciones, roles y usuarios.
- **Equipo Authly:** quiere que solo accedan administradores con cuenta y credenciales válidas.

Precondiciones

Ninguna.

Garantías mínimas

- No se otorga acceso con credenciales inválidas.
- No se revela si el error se debe al email o a la contraseña.

Garantías de éxito

El Administrador tiene una sesión activa en el panel mientras esta no venza.

Escenario principal de éxito

N.°	Acción
1	El Administrador ingresa su email y contraseña.
2	El sistema valida que exista una cuenta de administrador con ese email y que la contraseña sea correcta.
3	El sistema le otorga acceso al panel con una sesión activa.

Extensiones

1a. El Administrador no recuerda su contraseña:

1a.1. El Administrador recupera su contraseña (AU-CU-10).

1a.2. Vuelve al paso 1.

2a. Las credenciales son inválidas (cuenta de administrador inexistente o contraseña incorrecta):

2a.1. El sistema informa «Credenciales inválidas», sin distinguir la causa.

2a.2. El Administrador reintenta (vuelve al paso 1) o abandona (el caso termina sin éxito).

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-05 (Política de mensajes); AURN-06 (Sesiones y tokens); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).

Variaciones de tecnología y datos

Ninguna identificada.

Frecuencia de ocurrencia

Alta. Cada vez que un administrador inicia sesión o su sesión vence.

Cuestiones abiertas

- Confirmar la duración de la sesión de 8 horas (AURN-06). Cuanto más larga, más cómodo es el panel, pero más dura la exposición si se filtra una sesión, porque no puede revocarse.
- Sin bloqueo por fuerza bruta (AUPB-03). La complejidad de la contraseña (AURN-01, mínimo 10 caracteres con mayúscula, minúscula, número y símbolo) ya hace impráctico el ataque online. La versión simple de bloqueo (por cuenta) permitiría a un tercero bloquear al único Administrador de la organización, que es un riesgo peor que el que mitiga. La mitigación real sería un límite por dirección IP, que es más que mínimo indispensable y queda en el backlog. Pendiente de la consulta 2 al profesor.

Product Backlog vinculado

- AUPB-03 Bloqueo por fuerza bruta
- AUPB-04 Renovar sesión (refresh token)
- AUPB-05 Cerrar sesión con invalidación

Retirado o descartado en este caso:

- AUPB-09, recuperar cuentas no verificadas en el login: descartado, ya no existen cuentas inactivas.

3. AU-CU-03: Gestionar aplicaciones de la organización

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Administrador de Organización
Disparador	El Administrador necesita configurar las aplicaciones de su organización.

Interesados e intereses

- **Administrador de Organización:** quiere registrar sus aplicaciones y obtener las credenciales para que los sistemas externos se conecten a Authly.
- **Sistema Externo:** necesita credenciales válidas de su aplicación para consumir la API.
- **Equipo Authly:** quiere que las credenciales estén protegidas y que los nombres de aplicación sean únicos dentro de la organización.

Precondiciones

El Administrador está autenticado en el panel (AU-CU-02).

Garantías mínimas

- Solo se gestionan aplicaciones de la organización del Administrador.
- No se crea una aplicación con un nombre ya existente en la organización, ni se le asigna uno ya existente al editarla.
- El client secret nunca se conserva en texto plano y solo se entrega al crearlo o regenerarlo.
- Nunca quedan dos secrets válidos para la misma aplicación.
- Si el Administrador cancela la regeneración, el secret vigente no cambia.
- No se elimina una aplicación que tenga usuarios asignados en alguno de sus roles.
- Si la operación de editar o eliminar no se completa, la aplicación no se modifica.

Garantías de éxito

- **Al crear:** existe una aplicación en la organización con su client ID y su client secret, y el Administrador los conoce.
- **Al regenerar:** el secret anterior deja de ser válido y el Administrador conoce el nuevo.
- **Al editar:** la aplicación tiene el nombre y la descripción indicados.
- **Al eliminar:** la aplicación y sus roles dejan de existir, y sus credenciales (client ID y secret) dejan de ser válidas.

Escenario principal de éxito (crear aplicación)

N.°	Acción
1	El Administrador solicita crear una aplicación e ingresa su nombre y, opcionalmente, una descripción.
2	El sistema valida que el nombre sea único dentro de la organización.
3	El sistema crea la aplicación y genera su client ID y su client secret.
4	El sistema informa ambos al Administrador, indicando que el secret no volverá a verse. La aplicación queda lista para configurarse.

Extensiones

1a. El Administrador selecciona una aplicación existente y solicita regenerar su client secret:

1a.1. El sistema advierte que el secret actual quedará invalidado y que los sistemas externos que lo usen dejarán de funcionar hasta configurar el nuevo.

1a.2. El Administrador confirma.

1a.3. El sistema genera un nuevo secret e invalida el anterior.

1a.4. El sistema informa el nuevo secret, indicando que no volverá a verse. El caso termina con éxito.

1a.2a. El Administrador cancela:

1a.2a.1. El sistema no modifica nada. El caso termina sin cambios.

1b. El Administrador selecciona una aplicación existente y solicita editarla (modificar su nombre, su descripción, o ambos):

1b.1. El Administrador ingresa el nombre, la descripción, o ambos, y confirma.

1b.2. El sistema valida que el nombre sea único dentro de la organización, sin contar la aplicación que se está editando.

1b.3. El sistema actualiza la aplicación e informa el resultado. El caso termina con éxito.

1b.2a. El nombre ya existe en otra aplicación de la organización:

1b.2a.1. El sistema informa el conflicto.

1b.2a.2. El Administrador ingresa otro nombre (vuelve al paso 1b.1) o abandona (el caso termina sin éxito y la aplicación queda sin cambios).

1c. El Administrador selecciona una aplicación existente y solicita eliminarla:

1c.1. El sistema verifica que la aplicación no tenga usuarios asignados en ninguno de sus roles.

1c.2. El sistema solicita confirmación: indica que se eliminarán también los roles y permisos de la aplicación, que los sistemas externos que usen sus credenciales dejarán de funcionar y que la acción no se puede deshacer, y pide escribir el nombre exacto de la aplicación.

1c.3. El Administrador escribe el nombre y confirma.

1c.4. El sistema elimina la aplicación junto con sus roles e informa el resultado. El caso termina con éxito.

1c.1a. La aplicación tiene usuarios asignados:

1c.1a.1. El sistema informa cuántos usuarios tiene e indica que deben eliminarse primero desde la gestión de usuarios (AU-CU-06).

1c.1a.2. El caso termina sin éxito.

1c.3a. Lo que el Administrador escribe no coincide con el nombre de la aplicación (sin distinguir mayúsculas ni espacios sobrantes, AURN-03):

1c.3a.1. El sistema no habilita la confirmación.

1c.3a.2. El Administrador corrige (vuelve al paso 1c.3) o cancela (el caso termina sin cambios).

1c.3b. El Administrador cancela:

1c.3b.1. El sistema no modifica nada. El caso termina sin cambios.

1c.4a. Entre la verificación del paso 1c.1 y la eliminación, la aplicación pasó a tener usuarios (por ejemplo, porque se registró uno mientras se escribía la confirmación):

1c.4a.1. El sistema no elimina nada e informa que la aplicación ahora tiene usuarios.

1c.4a.2. El caso termina sin éxito.

2a. El nombre ya existe en la organización:

2a.1. El sistema informa el conflicto.

2a.2. El Administrador ingresa otro nombre (vuelve al paso 1) o abandona (el caso termina sin éxito).

Requisitos especiales

- Reglas y restricciones aplicables: AURN-03 (Comparación de textos y datos con formato); AURN-05 (Política de mensajes); AURN-08 (Credenciales de aplicación); AURN-09 (Aislamiento y poblaciones); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Nombre de la aplicación: obligatorio. Descripción: opcional.
- El panel presenta siempre el client ID junto a la lista de aplicaciones.
- Es responsabilidad del Administrador comunicar las credenciales a los equipos de los Sistemas Externos por un medio seguro.
- Para eliminar, el Administrador debe escribir el nombre exacto de la aplicación (AURN-03: sin distinguir mayúsculas ni espacios sobrantes).
- Eliminar una aplicación elimina también sus roles y permisos, y deja sin efecto sus credenciales (client ID y secret) de inmediato.
- El listado de aplicaciones está paginado y muestra, para cada una, la cantidad de usuarios que tiene. También muestra el total de aplicaciones y el total de usuarios de la organización.

Variaciones de tecnología y datos

Ninguna identificada.

Frecuencia de ocurrencia

Baja. Al configurar la organización y ante regeneraciones, ediciones o eliminaciones esporádicas.

Cuestiones abiertas

Si el Administrador no copia el client secret después de crearlo o regenerarlo, lo pierde para siempre. La única forma de recuperarlo es regenerar (extensión 1a), lo que invalida el anterior y rompe a los Sistemas Externos que lo estén usando.

Product Backlog vinculado

- AUPB-09 Desactivar y reactivar aplicación
- AUPB-10 Límite de aplicaciones por organización
- AUPB-11 URL de la aplicación

Retirado o descartado en este caso:

- AUPB-07, Editar aplicación: retirado, pasó al MVP (extensión 1b).
- AUPB-08, Eliminar aplicación: retirado, pasó al MVP (extensión 1c), con una diferencia respecto de la idea original: en lugar de eliminar en cascada también a los usuarios, se bloquea la eliminación mientras la aplicación tenga usuarios, que deben eliminarse antes desde la gestión de usuarios (AU-CU-06).

4. AU-CU-04: Gestionar roles y permisos de una aplicación

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Administrador de Organización
Disparador	El Administrador necesita definir o ajustar los roles de una aplicación.

Interesados e intereses

- **Administrador de Organización:** quiere definir qué puede hacer cada tipo de usuario de su aplicación, mediante roles con permisos.
- **Sistema Externo:** necesita que existan roles con permisos definidos para poder autorizar a sus usuarios.
- **Equipo Authly:** quiere nombres de rol únicos dentro de la aplicación y permisos con formato recurso + acción.

Precondiciones

- El Administrador está autenticado en el panel (AU-CU-02).
- Existe al menos una aplicación en su organización (AU-CU-03).

Garantías mínimas

- Solo se gestionan roles de aplicaciones de la organización del Administrador.
- No existen dos roles con el mismo nombre en una aplicación.
- No se elimina un rol que tenga usuarios asignados.
- Si la operación no se completa, el rol no se modifica.

Garantías de éxito

- **Al crear:** existe un rol con nombre único en la aplicación y con los permisos indicados, que pueden ser ninguno.
- **Al modificar:** el rol tiene el nombre y los permisos indicados.
- **Al eliminar:** el rol y sus permisos dejan de existir.
- Si el rol se marcó como por defecto, es el único rol por defecto de la aplicación.

Escenario principal de éxito (crear rol)

N.°	Acción
1	El Administrador solicita crear un rol e ingresa su nombre, sus permisos (cada uno con recurso y acción, o ninguno) y, opcionalmente, lo marca como rol por defecto.
2	El sistema valida que el nombre sea único en la aplicación y que los permisos ingresados estén completos y no se repitan.
3	El sistema guarda el rol con sus permisos e informa el resultado.

Extensiones

1a. El Administrador selecciona un rol existente y solicita modificarlo:

1a.1. El Administrador cambia el nombre, agrega o quita permisos, o cambia la marca de rol por defecto, y solicita guardar. Continúa en el paso 2.

1b. El Administrador selecciona un rol existente y solicita eliminarlo:

1b.1. El sistema verifica que el rol no tenga usuarios asignados.

1b.2. El sistema solicita confirmación, indicando que se eliminarán el rol y sus permisos, y avisando si es el rol por defecto (la aplicación quedaría sin ninguno y no podría registrar usuarios nuevos hasta marcar otro).

1b.3. El Administrador confirma.

1b.4. El sistema elimina el rol con sus permisos e informa el resultado. El caso termina con éxito.

1b.1a. El rol tiene usuarios asignados:

1b.1a.1. El sistema informa cuántos usuarios lo tienen y que deben cambiarles el rol o eliminarlos desde la gestión de usuarios (AU-CU-06).

1b.1a.2. El caso termina sin éxito.

1b.3a. El Administrador cancela:

1b.3a.1. El sistema no modifica nada. El caso termina sin cambios.

1b.4a. Entre la verificación y la eliminación, el rol pasó a tener usuarios asignados (por ejemplo, porque un usuario se registró y recibió ese rol como rol por defecto):

1b.4a.1. El sistema no elimina nada e informa que el rol ahora tiene usuarios.

1b.4a.2. El caso termina sin éxito.

2a. Otro rol de la aplicación ya tiene ese nombre:

2a.1. El sistema informa el conflicto.

2a.2. El Administrador ingresa otro nombre (vuelve al paso 1, o al 1a.1 si estaba modificando) o abandona (el caso termina sin éxito y el rol queda sin cambios).

2b. Los permisos son inválidos (con recurso o acción vacíos, o repetidos):

2b.1. El sistema informa cuáles son inválidos.

2b.2. El Administrador corrige (vuelve al paso 1, o al 1a.1 si estaba modificando) o abandona (el caso termina sin éxito y el rol queda sin cambios).

3a. Se marcó el rol como por defecto y otro rol de la aplicación ya lo era:

3a.1. El sistema le quita la marca al otro rol y se la asigna a este.

3a.2. El sistema guarda el rol e informa el resultado, indicando además cuál era el rol por defecto anterior. El caso termina con éxito.

3b. Se quitó la marca de rol por defecto a un rol que la tenía:

3b.1. El sistema advierte que no se podrán registrar usuarios nuevos hasta marcar otro rol y solicita confirmación.

3b.2. El Administrador confirma.

3b.3. El sistema guarda el rol e informa el resultado. El caso termina con éxito.

3b.2a. El Administrador cancela:

3b.2a.1. El sistema no modifica nada. El caso termina sin cambios.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-03 (Comparación de textos y datos con formato); AURN-05 (Política de mensajes); AURN-09 (Aislamiento y poblaciones); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Nombre del rol: obligatorio.
- Permiso: par recurso + acción, ambos obligatorios y de texto libre. No se admiten pares repetidos dentro de un rol.
- Un rol puede no tener permisos. Sirve, por ejemplo, para un rol por defecto de mínimos privilegios: el usuario existe y no puede hacer nada hasta que el Administrador le asigne otro rol.
- Los permisos pertenecen al rol: quitar un permiso de un rol no afecta a los demás roles.
- El par recurso + acción es un contrato entre el Administrador y el equipo del Sistema Externo. Authly no valida que existan en ese sistema.
- Solo puede haber un rol por defecto por aplicación, y la aplicación puede no tener ninguno. Sin rol por defecto no se pueden registrar usuarios (AU-CU-05).
- El rol por defecto debería ser el de menores privilegios, porque todo usuario nuevo recibirá sus permisos. Esa responsabilidad es del Administrador.
- Los cambios en un rol se aplican a todos los usuarios que lo tengan asignado.
- El panel lista los roles de la aplicación con sus permisos e indica cuál es el rol por defecto.

Variaciones de tecnología y datos

Ninguna identificada.

Frecuencia de ocurrencia

Media. Al configurar la aplicación y cuando cambian los requerimientos de autorización.

Cuestiones abiertas

Ninguna.

Product Backlog vinculado

- AUPB-12 Log de auditoría (transversal)

Retirado o descartado en este caso:

- AUPB-16, eliminar rol: retirado, pasó al MVP (extensión 1b).
- AUPB-18, plantillas de roles: descartado.
- Permisos compartidos entre roles, con aviso de eliminación de permisos huérfanos: descartado, los permisos pertenecen al rol.

5. AU-CU-05: Registrar usuario en una aplicación (vía API)

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Sistema Externo
Actor secundario	Servicio de correo
Disparador	Un usuario final se da de alta en el Sistema Externo, y este solicita a Authly registrarlo.

Interesados e intereses

- **Sistema Externo:** quiere delegar en Authly la creación de la cuenta de su usuario y el resguardo de su contraseña, con la garantía de que el email es del usuario.
- **Usuario final:** quiere tener una cuenta en el Sistema Externo, y que nadie cree una cuenta con su email sin su consentimiento.
- **Administrador de Organización:** quiere que los usuarios queden en su aplicación con el rol por defecto que definió, y que nadie pueda crearlos sin las credenciales de la aplicación.
- **Equipo Authly:** quiere emails verificados y únicos por aplicación, contraseñas protegidas y aplicaciones aisladas entre sí.

Precondiciones

Ninguna.

Garantías mínimas

- No se crea ningún usuario si las credenciales de la aplicación son inválidas.
- No se crea ningún usuario si los datos son inválidos o el email ya está registrado en la aplicación.
- No se crea ningún usuario si el email no se verificó con un código válido.
- Ningún usuario se crea sin rol asignado.
- El usuario se crea solo en la aplicación a la que corresponden las credenciales presentadas.
- La contraseña nunca se conserva en texto plano.

Garantías de éxito

- Existe un usuario con email verificado, asociado a la aplicación, con el rol por defecto asignado.
- El Sistema Externo conoce el identificador del usuario creado.

Escenario principal de éxito

N.°	Acción
1	El Sistema Externo envía las credenciales de la aplicación y los datos del usuario (email, contraseña, nombre y apellido).
2	El sistema valida las credenciales de la aplicación.
3	El sistema valida que los datos sean correctos, que el email no esté registrado en la aplicación y que la aplicación tenga un rol por defecto.
4	El sistema envía un código de verificación de 6 dígitos al email del usuario.
5	El Sistema Externo envía el código de verificación, junto con las credenciales de la aplicación y los datos del paso 1.
6	El sistema repite las validaciones de los pasos 2 y 3 y valida el código.
7	El sistema crea el usuario en la aplicación, le asigna el rol por defecto e informa el éxito y el identificador del usuario.

Extensiones

2a. Las credenciales de la aplicación son inválidas:

2a.1. El sistema rechaza la solicitud sin distinguir la causa.

2a.2. El caso termina sin éxito.

3a. Los datos son inválidos (faltantes, email con formato incorrecto o contraseña que no cumple la complejidad):

3a.1. El sistema informa cada campo y regla incumplida.

3a.2. El caso termina sin éxito. El Sistema Externo puede iniciar una nueva solicitud con los datos corregidos.

3b. El email ya está registrado en la aplicación:

3b.1. El sistema informa el conflicto.

3b.2. El caso termina sin éxito.

3c. La aplicación no tiene rol por defecto:

3c.1. El sistema informa que la aplicación no está configurada para registrar usuarios, indicando que falta marcar un rol por defecto, y no crea nada.

3c.2. El caso termina sin éxito.

4a. No se pudo enviar el email:

4a.1. El sistema deja constancia para el equipo de Authly, informa que no pudo enviar el código y no crea nada.

4a.2. El caso termina sin éxito. El Sistema Externo puede iniciar una nueva solicitud.

4b. Ya existía un código pendiente para ese email en esa aplicación:

4b.1. El sistema invalida el código anterior y emite el nuevo. Continúa en el paso 5.

4c. Se alcanzó el límite de códigos para ese email en esa aplicación (AURN-04):

4c.1. El sistema no envía ningún código, informa que se superó el límite y cuándo podrá pedir uno nuevo, y no crea nada.

4c.2. El caso termina sin éxito.

6a. El código es incorrecto (incluye que el email reenviado sea distinto del del paso 1):

6a.1. El sistema informa que el código es incorrecto e indica cuántos intentos restan.

6a.2. El Sistema Externo reintenta. Vuelve al paso 5.

6b. El código es incorrecto y se agotaron los 5 intentos:

6b.1. El sistema invalida el código e informa que el registro debe reiniciarse.

6b.2. El caso termina sin éxito.

6c. El código expiró:

6c.1. El sistema informa que el código expiró y que el registro debe reiniciarse.

6c.2. El caso termina sin éxito.

6d. Alguna validación de los pasos 2 o 3 ya no se cumple al reenviar los datos (por ejemplo, se regeneró el secret de la aplicación o se eliminó el rol por defecto):

6d.1. El sistema no crea nada y responde como en la extensión correspondiente (2a, 3a, 3b o 3c).

6d.2. El caso termina sin éxito.

7a. Entre la validación del paso 6 y la creación, otra solicitud registró el mismo email o la aplicación dejó de tener rol por defecto:

7a.1. El sistema no crea nada e informa el conflicto que corresponda.

7a.2. El caso termina sin éxito.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-04 (Código de verificación); AURN-05 (Política de mensajes); AURN-08 (Credenciales de aplicación); AURN-09 (Aislamiento y poblaciones); AURN-10 (Registro operativo); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Nombre y apellido: obligatorios.
- La creación del usuario y la asignación del rol son atómicas.
- El Sistema Externo no elige el rol: siempre se asigna el rol por defecto (AU-CU-04). Sin rol por defecto no se pueden registrar usuarios.
- Mientras espera el código, Authly no conserva los datos. El Sistema Externo los conserva y los reenvía, y es responsable de resguardar la contraseña durante ese lapso.
- El conflicto de email se informa de forma explícita (AURN-05).
- Authly no puede verificar que los datos reenviados en el paso 5 sean los mismos del paso 1, porque no los conserva. Si el Sistema Externo los cambia (nombre, apellido o contraseña), el usuario se crea con los nuevos. Es responsabilidad del Sistema Externo enviar los mismos datos.

Variaciones de tecnología y datos

Solicitudes y respuestas en JSON sobre HTTP (API REST). El código se envía por correo electrónico.

Frecuencia de ocurrencia

Media-alta. Cada vez que un usuario nuevo se da de alta en un sistema consumidor.

Cuestiones abiertas

- Validar con el profesor el criterio de no conservar los datos del registro mientras se espera el código (consulta 1).
- El límite de códigos por email (AURN-04) acota el envío repetido a una dirección, pero permite que un tercero agote el cupo de un email ajeno (riesgo aceptado). Un tercero con credenciales de aplicación aún podría hacer que Authly envíe correos a muchas direcciones distintas (AUPB-06).
- El destinatario recibe un correo de un remitente que no conoce. El nombre de la aplicación en el mensaje lo mitiga.

Product Backlog vinculado

- AUPB-02 Reenvío de código sin reiniciar
- AUPB-06 Límite de códigos por IP y contra abuso
- AUPB-14 Identidad compartida entre aplicaciones de una organización

Retirado o descartado en este caso:

- AUPB-20, verificación de email de usuarios de aplicación: retirado, pasó al MVP en este caso.
- Que el Sistema Externo indique el rol en la solicitud: descartado, le quitaría al Administrador el control del rol de los usuarios nuevos.

6. AU-CU-06: Gestionar usuarios de una aplicación

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Administrador de Organización
Disparador	El Administrador necesita ajustar los accesos de los usuarios de una aplicación.

Interesados e intereses

- **Administrador de Organización:** quiere controlar qué usuarios tienen acceso a su aplicación y con qué roles.
- **Usuarios de la aplicación:** su acceso y sus permisos dependen de las decisiones del Administrador.
- **Sistema Externo:** necesita que cada usuario tenga roles asignados para poder autorizarlo.
- **Equipo Authly:** quiere que ningún usuario quede sin rol y que las organizaciones estén aisladas entre sí.

Precondiciones

- El Administrador está autenticado en el panel (AU-CU-02).
- Existe al menos una aplicación en su organización (AU-CU-03).

Garantías mínimas

- Solo se gestionan usuarios de aplicaciones de la organización del Administrador.
- Ningún usuario queda sin al menos un rol.
- No se elimina un usuario sin confirmación.
- Si la operación no se completa, el usuario no se modifica.

Garantías de éxito

- **Al editar:** el usuario tiene el nombre, el apellido y exactamente los roles indicados, y sus permisos son la suma de los permisos de todos ellos.
- **Al eliminar:** el usuario deja de existir en la aplicación.

Escenario principal de éxito (editar usuario)

N.°	Acción
1	El Administrador consulta los usuarios de la aplicación con sus roles y selecciona uno.
2	El Administrador indica el nombre, el apellido y los roles que el usuario debe tener.
3	El sistema valida que el nombre y el apellido no estén vacíos, que el usuario tenga al menos un rol y que todos los roles existan en la aplicación.
4	El sistema actualiza el usuario con el nombre, el apellido y los roles indicados, en una sola operación, e informa el resultado.

Extensiones

1a. El Administrador selecciona un usuario y solicita eliminarlo:

1a.1. El sistema solicita confirmación, mostrando nombre, email y roles del usuario, e indicando que la eliminación es irreversible y que el usuario deberá registrarse y verificar su email de nuevo si quiere volver.

1a.2. El Administrador confirma.

1a.3. El sistema elimina el usuario e informa el resultado. El caso termina con éxito.

1a.3a. El usuario ya no existe al ejecutar la eliminación (por ejemplo, porque otra sesión lo eliminó):

1a.3a.1. El sistema informa y no modifica nada.

1a.3a.2. El caso termina sin éxito.

1a.2a. El Administrador cancela:

1a.2a.1. El sistema no modifica nada. El caso termina sin cambios.

3a. El nombre, el apellido, o ambos, están vacíos:

3a.1. El sistema informa qué campo falta.

3a.2. El Administrador corrige (vuelve al paso 2) o abandona (el caso termina sin cambios).

3b. Los roles indicados no incluyen ninguno:

3b.1. El sistema informa que el usuario debe tener al menos un rol.

3b.2. El Administrador corrige (vuelve al paso 2) o abandona (el caso termina sin cambios).

4a. El usuario o alguno de los roles dejó de existir mientras el Administrador operaba:

4a.1. El sistema no modifica nada e informa qué elemento ya no existe.

4a.2. El caso termina sin éxito.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-02 (Email); AURN-06 (Sesiones y tokens); AURN-09 (Aislamiento y poblaciones); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Un usuario siempre tiene al menos un rol, puede tener varios y sus permisos se suman.
- El listado está paginado y muestra, para cada usuario, su nombre, apellido, email y roles.
- El email del usuario no se puede modificar desde el panel. Nombre y apellido: obligatorios.
- Editar un usuario (nombre, apellido y roles) es una sola operación atómica: se guardan los tres juntos, o ninguno se modifica.
- Eliminar un usuario lo borra por completo. Su email queda libre para volver a registrarse, con una nueva verificación (AU-CU-05), y recibirá un identificador nuevo, así que las referencias del Sistema Externo al anterior dejan de valer. Su token sigue vigente hasta vencer (AURN-06).
- Los usuarios se crean solo por el registro vía API (AU-CU-05). El panel no los crea, y la contraseña no se gestiona desde el panel.
- Si el usuario ya no existe al confirmar una operación (por ejemplo, porque lo eliminó otra sesión del mismo Administrador), el sistema informa y no modifica nada.

Variaciones de tecnología y datos

Ninguna identificada.

Frecuencia de ocurrencia

Media-alta. Cada vez que el Administrador necesita ajustar accesos.

Cuestiones abiertas

Ninguna.

Product Backlog vinculado

- AUPB-15 Búsqueda y filtro en la lista de usuarios
- AUPB-16 Historial de actividad del usuario
- AUPB-17 Baja lógica de usuarios

Retirado o descartado en este caso:

- Editar el email de un usuario: descartado. El error de tipeo se corrige eliminando al usuario y registrándolo de nuevo.
- Eliminar de Authly a los usuarios que no pertenezcan a otra aplicación: descartado, con cuentas independientes por aplicación no existen usuarios compartidos. Reaparece solo si se implementa el AUPB-14.

7. AU-CU-07: Autenticar usuario de una aplicación (vía API)

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Sistema Externo
Disparador	Un usuario final intenta iniciar sesión en el Sistema Externo, y este solicita a Authly autenticarlo.

Interesados e intereses

- **Sistema Externo:** quiere verificar las credenciales de su usuario y obtener un token que acredite su identidad, sin implementar autenticación propia.
- **Usuario final:** quiere iniciar sesión en el Sistema Externo con su email y contraseña.
- **Administrador de Organización:** quiere que solo accedan los usuarios registrados en su aplicación, y que nadie pueda autenticarlos sin las credenciales de la aplicación.
- **Equipo Authly:** quiere aplicaciones aisladas entre sí y que no se revele qué cuentas existen.

Precondiciones

Ninguna.

Garantías mínimas

- No se emite ningún token si las credenciales de la aplicación son inválidas.
- No se emite ningún token si las credenciales del usuario son inválidas.
- No se revela si el fallo se debe al email o a la contraseña.
- Solo se autentican usuarios de la aplicación a la que corresponden las credenciales presentadas.

Garantías de éxito

El Sistema Externo obtiene un token de acceso que identifica al usuario y a su aplicación, y que es válido por un tiempo limitado.

Escenario principal de éxito

N.°	Acción
1	El Sistema Externo envía las credenciales de la aplicación y las del usuario (email y contraseña).
2	El sistema valida las credenciales de la aplicación.
3	El sistema valida que exista un usuario con ese email en la aplicación y que la contraseña sea correcta.
4	El sistema emite un token de acceso y se lo entrega al Sistema Externo.

Extensiones

1a. El usuario final no recuerda su contraseña:

1a.1. El Sistema Externo recupera la contraseña del usuario (AU-CU-11).

1a.2. Vuelve al paso 1.

2a. Las credenciales de la aplicación son inválidas:

2a.1. El sistema rechaza la solicitud sin distinguir la causa.

2a.2. El caso termina sin éxito.

3a. Las credenciales del usuario son inválidas (usuario inexistente en la aplicación o contraseña incorrecta):

3a.1. El sistema informa «Credenciales de usuario inválidas», sin distinguir la causa.

3a.2. El caso termina sin éxito. El Sistema Externo puede iniciar una nueva solicitud.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-05 (Política de mensajes); AURN-06 (Sesiones y tokens); AURN-08 (Credenciales de aplicación); AURN-09 (Aislamiento y poblaciones); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- El token identifica a un usuario y a su aplicación, y no se acepta como token de administrador. Su contenido mínimo está en el AURN-06.
- Un usuario eliminado (AU-CU-06) conserva un token vigente hasta que venza. El Sistema Externo puede detectarlo consultando permisos (AU-CU-09).

Variaciones de tecnología y datos

Solicitudes y respuestas en JSON sobre HTTP (API REST).

Frecuencia de ocurrencia

Alta. Cada vez que un usuario final inicia sesión en un sistema consumidor.

Cuestiones abiertas

- Confirmar la duración del token de 8 horas (AURN-06). Cuanto más larga, más cómodo es el sistema, pero más dura la exposición si se filtra un token o se elimina a un usuario.
- Sin bloqueo por fuerza bruta (AUPB-03), un atacante puede probar contraseñas sin límite. Lo atenúa que hace falta pasar por un Sistema Externo que tenga las credenciales de la aplicación. Pendiente de la consulta 2 al profesor.

Product Backlog vinculado

- AUPB-03 Bloqueo por fuerza bruta
- AUPB-04 Renovar sesión (refresh token)
- AUPB-05 Cerrar sesión con invalidación
- AUPB-18 Revocar el acceso de un usuario eliminado

Retirado o descartado en este caso:

- Extensión «cuenta inactiva»: descartada, no existen usuarios sin verificar (AU-CU-05).

8. AU-CU-08: Obtener la clave pública de validación (vía API)

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Sistema Externo
Disparador	El Sistema Externo necesita verificar tokens emitidos por Authly (por ejemplo, al iniciar) y solicita la clave pública.

Interesados e intereses

- **Sistema Externo:** quiere obtener la clave con la que verificar por su cuenta la autenticidad de los tokens de Authly, sin consultarlo en cada solicitud.
- **Equipo Authly:** quiere entregar la clave pública sin exponer la clave privada ni detalles internos.

Precondiciones

Ninguna.

Garantías mínimas

- Nunca se entrega ni se expone la clave privada.
- Si la clave no puede entregarse, el error no revela detalles internos.

Garantías de éxito

El Sistema Externo obtiene la clave pública vigente en un formato estándar.

Escenario principal de éxito

N.°	Acción
1	El Sistema Externo solicita la clave pública de validación.
2	El sistema entrega la clave pública vigente.

Extensiones

2a. El sistema no puede obtener la clave:

2a.1. El sistema informa un error genérico y deja constancia del fallo para el equipo de Authly.

2a.2. El caso termina sin éxito.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-06 (Sesiones y tokens); AURN-10 (Registro operativo); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Acceso público: no requiere credenciales de aplicación. Formato PEM.
- El Sistema Externo debe verificar, con los datos del propio token (AURN-06), que este pertenece a su aplicación y a un usuario, no a un administrador.

Variaciones de tecnología y datos

Respuesta HTTP con la clave en formato PEM.

Frecuencia de ocurrencia

Muy baja. Una vez al iniciar cada Sistema Externo.

Cuestiones abiertas

- La clave no rota en el MVP. Si cambiara, los tokens vigentes dejarían de verificarse y el Sistema Externo no sabría cuándo volver a pedirla (AUPB-20).
- Es el caso más chico del modelo (2 pasos): Authly solo entrega un dato y la complejidad la tiene el consumidor. Se mantiene como caso propio por el criterio de nivel. Consulta 4 al profesor.

Product Backlog vinculado

- AUPB-19 Validar token en Authly
- AUPB-20 Rotación de claves y formato JWKS

9. AU-CU-09: Verificar permiso de un usuario (vía API)

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Objetivo de usuario
Actor principal	Sistema Externo
Disparador	El Sistema Externo debe decidir si atiende la solicitud de un usuario final y consulta a Authly si ese usuario tiene el permiso necesario.

Interesados e intereses

- **Sistema Externo:** quiere saber si un usuario puede realizar una acción sobre un recurso, para atender o rechazar su solicitud, sin implementar su propio control de roles.
- **Administrador de Organización:** quiere que los permisos que definió se apliquen con sus cambios de inmediato, y que solo su aplicación pueda consultarlos.
- **Usuario final:** su acceso depende de los roles que se le asignaron.
- **Equipo Authly:** quiere aplicaciones aisladas entre sí y que nunca se otorgue un permiso que el usuario no tiene.

Precondiciones

Ninguna.

Garantías mínimas

- Nunca se informa que un usuario tiene un permiso si no lo tiene en alguno de sus roles vigentes.
- No se responde ninguna consulta si las credenciales de la aplicación son inválidas.
- No se responde ninguna consulta si el token del usuario es inválido, venció, pertenece a otra aplicación o no corresponde al usuario consultado.
- Solo se consultan usuarios de la aplicación a la que corresponden las credenciales presentadas.

Garantías de éxito

El Sistema Externo conoce si el usuario tiene el permiso consultado, según los roles que tiene en ese momento.

Escenario principal de éxito

N.°	Acción
1	El Sistema Externo envía las credenciales de la aplicación, el token del usuario, el identificador del usuario y el permiso consultado (recurso y acción).
2	El sistema valida las credenciales de la aplicación y el token: firma, vencimiento, que sea un token de usuario de esa aplicación y que identifique al mismo usuario consultado.
3	El sistema valida que la consulta esté completa y que el usuario exista en la aplicación.
4	El sistema determina si el usuario tiene ese permiso en alguno de sus roles.
5	El sistema informa al Sistema Externo si el usuario tiene el permiso.

Extensiones

2a. Las credenciales de la aplicación son inválidas:

2a.1. El sistema rechaza la solicitud sin distinguir la causa.

2a.2. El caso termina sin éxito.

2b. El token es inválido, venció, es de otra aplicación o no corresponde al usuario consultado:

2b.1. El sistema rechaza la solicitud sin distinguir la causa.

2b.2. El caso termina sin éxito.

3a. La consulta está incompleta (falta el usuario, el recurso o la acción):

3a.1. El sistema informa qué falta.

3a.2. El caso termina sin éxito.

3b. El usuario no existe en la aplicación (por ejemplo, fue eliminado):

3b.1. El sistema informa que el usuario no existe en la aplicación.

3b.2. El caso termina sin éxito.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-03 (Comparación de textos y datos con formato); AURN-05 (Política de mensajes); AURN-06 (Sesiones y tokens); AURN-08 (Credenciales de aplicación); AURN-09 (Aislamiento y poblaciones); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Una respuesta negativa (el usuario existe pero no tiene el permiso) es un resultado válido del caso, no un fallo.
- Un usuario inexistente es un fallo y se informa de forma explícita (AURN-05). Es responsabilidad del Sistema Externo denegar el acceso ante cualquier error de este caso.
- Los permisos de un usuario son la suma de los de todos sus roles (AU-CU-06).
- Los cambios de roles y permisos y la eliminación de usuarios se reflejan en la consulta siguiente, a diferencia del token, que no puede revocarse.
- El Sistema Externo valida el token (AU-CU-08) para autenticar al usuario, y Authly lo vuelve a validar en cada consulta, para no depender del identificador que envía el Sistema Externo.
- Una consulta por permiso, con respuesta sí o no, sin listar los roles del usuario. La consulta no modifica ningún dato.

Variaciones de tecnología y datos

Solicitudes y respuestas en JSON sobre HTTP (API REST).

Frecuencia de ocurrencia

Muy alta. Una vez por cada acción protegida de un usuario final.

Cuestiones abiertas

Como hay una consulta por decisión, la latencia y la disponibilidad de Authly afectan a los Sistemas Externos. Es una consecuencia de la decisión, mitigable con el AUPB-21.

Product Backlog vinculado

- AUPB-21 Consultar todos los permisos de un usuario

Retirado o descartado en este caso:

- Incluir los permisos dentro del token: descartado, los cambios tardarían hasta 8 horas en aplicarse.
- Responder «no tiene el permiso» ante un usuario inexistente: descartado, se prefirió informar el error de forma explícita.

10. AU-CU-10: Recuperar la contraseña de un administrador

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Subfunción
Actor principal	Administrador de Organización
Actor secundario	Servicio de correo
Disparador	El Administrador no recuerda su contraseña y necesita recuperar el acceso.

Interesados e intereses

- **Administrador de Organización:** quiere recuperar el acceso al panel cuando olvidó su contraseña, sin depender del equipo de Authly.
- **Equipo Authly:** quiere que solo quien controla el email de la cuenta pueda cambiar su contraseña, y que el proceso no revele qué cuentas existen.

Precondiciones

Ninguna.

Garantías mínimas

- La contraseña no cambia sin un código válido enviado al email de la cuenta.
- No se revela si un email corresponde a una cuenta de administrador.
- Si el proceso no se completa, la contraseña vigente no cambia.

Garantías de éxito

- La cuenta tiene la contraseña nueva y la anterior deja de servir para iniciar sesión.
- El código utilizado deja de ser válido.

Escenario principal de éxito

N.°	Acción
1	El Administrador solicita recuperar su contraseña e ingresa su email.
2	El sistema envía un código de verificación de 6 dígitos a ese email e informa que lo recibirá si la cuenta existe.
3	El Administrador ingresa el código recibido y su nueva contraseña con su confirmación.
4	El sistema valida el código y, si es válido, que las contraseñas coincidan, que la nueva cumpla los requisitos de complejidad y que sea distinta de la actual.
5	El sistema actualiza la contraseña de la cuenta. La recuperación está completa.

Extensiones

2a. El email no corresponde a una cuenta de administrador (o su formato es inválido):

2a.1. El sistema no envía ningún código e informa lo mismo que en el paso 2. Continúa en el paso 3.

2b. No se pudo enviar el email:

2b.1. El sistema deja constancia para el equipo de Authly e informa lo mismo que en el paso 2. Continúa en el paso 3.

2c. Ya existía un código pendiente para ese email:

2c.1. El sistema invalida el código anterior y emite el nuevo. Continúa en el paso 3.

2d. Se alcanzó el límite de códigos para ese email (AURN-04):

2d.1. El sistema no envía ningún código e informa lo mismo que en el paso 2. Continúa en el paso 3.

4a. El código es inválido o venció (incluye que nunca se haya emitido uno):

4a.1. El sistema informa «Código inválido o vencido», sin distinguir la causa. Cada código incorrecto consume un intento y, al quinto, el código se invalida.

4a.2. El Administrador reintenta (vuelve al paso 3), reinicia la recuperación (vuelve al paso 1) o abandona (el caso termina sin éxito y la contraseña no cambia).

4b. El código es válido, pero las contraseñas no coinciden, la nueva no cumple la complejidad o es igual a la actual:

4b.1. El sistema informa el motivo y, si corresponde, qué requisitos faltan. No consume intentos del código.

4b.2. El Administrador corrige. Vuelve al paso 3.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-04 (Código de verificación); AURN-05 (Política de mensajes); AURN-06 (Sesiones y tokens); AURN-10 (Registro operativo); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Solo alcanza a cuentas de administrador. Los usuarios de aplicación tienen su propio caso (AU-CU-11).
- Las sesiones abiertas antes del cambio siguen vigentes hasta que venzan (AURN-06).

Variaciones de tecnología y datos

El código se envía por correo electrónico.

Frecuencia de ocurrencia

Baja.

Cuestiones abiertas

- La protección contra averiguar qué emails existen es parcial, porque el AU-CU-01 informa explícitamente que un email ya está registrado.
- Un tercero que conoce el email puede agotar el límite de códigos (AURN-04) o pisar el código pendiente, y el Administrador no podrá recuperar su contraseña durante una hora. Con un solo Administrador por organización, afecta a toda la organización. Con respuesta genérica, no recibe ningún aviso del motivo. Riesgo aceptado para el MVP (consulta 2). La solución de fondo es el AUPB-27.
- El límite de códigos por email no impide el envío a muchas direcciones distintas (AUPB-06).
- Si el Administrador recupera su contraseña por sospecha de acceso ajeno, esa persona conserva su sesión hasta 8 horas (AUPB-23).

Product Backlog vinculado

- AUPB-02 Reenvío de código sin reiniciar
- AUPB-06 Límite de códigos por IP y contra abuso
- AUPB-22 Cambiar contraseña conociendo la actual
- AUPB-23 Invalidar sesiones al cambiar la contraseña
- AUPB-24 Notificar el cambio de contraseña
- AUPB-27 Código de recuperación más largo

Retirado o descartado en este caso:

- Recuperar contraseña de usuario de aplicación como caso separado: retirado, pasó a ser el AU-CU-11.

11. AU-CU-11: Recuperar la contraseña de un usuario de una aplicación (vía API)

Alcance	Authly, plataforma de autenticación y autorización
Nivel	Subfunción
Actor principal	Sistema Externo
Actor secundario	Servicio de correo
Disparador	Un usuario final no recuerda su contraseña y solicita recuperarla en el Sistema Externo, y este solicita a Authly iniciar la recuperación.

Interesados e intereses

- **Sistema Externo:** quiere que su usuario recupere el acceso sin manejar contraseñas ni códigos.
- **Usuario final:** quiere recuperar su cuenta cuando olvidó su contraseña, y que nadie más pueda cambiarla.
- **Administrador de Organización:** quiere que solo quien controla el email del usuario pueda cambiar su contraseña, y que solo su aplicación pueda iniciar el proceso.
- **Equipo Authly:** quiere aplicaciones aisladas entre sí y que no se revele qué usuarios existen.

Precondiciones

Ninguna.

Garantías mínimas

- La contraseña no cambia sin un código válido enviado al email del usuario.
- No se procesa ninguna solicitud si las credenciales de la aplicación son inválidas.
- Solo se recuperan usuarios de la aplicación a la que corresponden las credenciales presentadas.
- No se revela si un email corresponde a un usuario de la aplicación.
- Si el proceso no se completa, la contraseña vigente no cambia.

Garantías de éxito

- El usuario tiene la contraseña nueva y la anterior deja de servir para autenticarse.
- El código utilizado deja de ser válido.

Escenario principal de éxito

N.°	Acción
1	El Sistema Externo envía las credenciales de la aplicación y el email del usuario.
2	El sistema valida las credenciales de la aplicación y que la solicitud esté completa.
3	El sistema envía un código de verificación de 6 dígitos al email e informa que el usuario lo recibirá si la cuenta existe.
4	El Sistema Externo envía el código de verificación, junto con las credenciales de la aplicación, el email y la contraseña nueva.
5	El sistema valida las credenciales de la aplicación y el código y, si el código es válido, que la contraseña cumpla los requisitos de complejidad y que sea distinta de la actual.
6	El sistema actualiza la contraseña del usuario e informa el éxito al Sistema Externo.

Extensiones

2a. Las credenciales de la aplicación son inválidas:

2a.1. El sistema rechaza la solicitud sin distinguir la causa.

2a.2. El caso termina sin éxito.

2b. La solicitud está incompleta (falta el email):

2b.1. El sistema informa qué falta.

2b.2. El caso termina sin éxito.

3a. El email no corresponde a un usuario de la aplicación (o su formato es inválido):

3a.1. El sistema no envía ningún código e informa lo mismo que en el paso 3. Continúa en el paso 4.

3b. No se pudo enviar el email:

3b.1. El sistema deja constancia para el equipo de Authly e informa lo mismo que en el paso 3. Continúa en el paso 4.

3c. Ya existía un código pendiente para ese email en esa aplicación:

3c.1. El sistema invalida el código anterior y emite el nuevo. Continúa en el paso 4.

3d. Se alcanzó el límite de códigos para ese email en esa aplicación (AURN-04):

3d.1. El sistema no envía ningún código e informa lo mismo que en el paso 3. Continúa en el paso 4.

5a. Las credenciales de la aplicación dejaron de ser válidas (por ejemplo, se regeneró el secret):

5a.1. El sistema responde como en la extensión 2a.

5a.2. El caso termina sin éxito.

5b. El código es inválido o venció (incluye que nunca se haya emitido uno, o que el usuario ya no exista):

5b.1. El sistema informa «Código inválido o vencido», sin distinguir la causa. Cada código incorrecto consume un intento y, al quinto, el código se invalida.

5b.2. El Sistema Externo reintenta (vuelve al paso 4), reinicia la recuperación (vuelve al paso 1) o abandona (el caso termina sin éxito y la contraseña no cambia).

5c. El código es válido, pero la contraseña no cumple los requisitos de complejidad, es igual a la actual o falta:

5c.1. El sistema informa el motivo y, si corresponde, qué requisitos faltan. No consume intentos del código.

5c.2. El Sistema Externo reintenta. Vuelve al paso 4.

Requisitos especiales

- Reglas y restricciones aplicables: AURN-01 (Contraseña); AURN-02 (Email); AURN-04 (Código de verificación); AURN-05 (Política de mensajes); AURN-06 (Sesiones y tokens); AURN-08 (Credenciales de aplicación); AURN-09 (Aislamiento y poblaciones); AURN-10 (Registro operativo); además rigen para todos los casos AURN-07 (Transporte) y AURN-11 (Alcance del MVP).
- Solo alcanza a usuarios de aplicación. Los administradores tienen su propio caso (AU-CU-10).
- La respuesta es genérica para que el Sistema Externo pueda retransmitirla al usuario sin revelar quién usa la aplicación (AURN-05).
- Los tokens emitidos antes del cambio siguen vigentes hasta que venzan (AURN-06).

Variaciones de tecnología y datos

Solicitudes y respuestas en JSON sobre HTTP (API REST). El código se envía por correo electrónico.

Frecuencia de ocurrencia

Baja.

Cuestiones abiertas

- La protección contra averiguar qué usuarios existen es parcial, porque el AU-CU-05 informa explícitamente que un email ya está registrado.
- Un tercero que conoce el email puede agotar el límite de códigos (AURN-04) o pisar el código pendiente, y el usuario no podrá recuperar su contraseña durante una hora. Riesgo aceptado para el MVP (consulta 2). La solución de fondo es el AUPB-27.
- El límite de códigos por email no impide el envío a muchas direcciones distintas (AUPB-06).
- Con respuesta genérica, el Sistema Externo no puede saber si el correo se envió ni si se alcanzó el límite de códigos, y quien escribe mal su email no recibe ningún aviso.

Product Backlog vinculado

- AUPB-02 Reenvío de código sin reiniciar
- AUPB-06 Límite de códigos por IP y contra abuso
- AUPB-22 Cambiar contraseña conociendo la actual
- AUPB-23 Invalidar sesiones al cambiar la contraseña
- AUPB-24 Notificar el cambio de contraseña
- AUPB-27 Código de recuperación más largo

7. Product Backlog

Funcionalidades diferidas por el criterio de mínimo indispensable. No son un compromiso: se retoman si hay tiempo.

ID	Funcionalidad	Descripción	Casos
AUPB-01	Invitar a un administrador adicional	Modelar como dos casos: «Invitar a un administrador» (enlace atado a un email, vence a las 72 h, un solo uso) y «Registrarse por invitación» (crea una cuenta de administrador asociada a la organización del invitante, sin organización nueva). Requiere definir la baja de administradores y qué pasa si el email ya es administrador de otra organización. Si el enlace prueba el control del email, el código de 6 dígitos sobra en el segundo caso.	01
AUPB-02	Reenvío de código sin reiniciar	Cuando el código expira o se agotan los intentos, permitir solicitar uno nuevo, invalidando el anterior, sin volver a ingresar todos los datos.	01, 05, 10, 11
AUPB-03	Bloqueo por fuerza bruta	Tras 5 intentos fallidos consecutivos, la cuenta se bloquea 15 minutos. La versión por cuenta se descartó para el MVP porque permite a un tercero bloquear al único Administrador de la organización, un riesgo peor que el que mitiga (la complejidad de la contraseña ya frena el ataque online). La alternativa preferida es un límite por dirección IP, que frena el scripting masivo sin dar un arma contra una persona puntual. Pendiente de la consulta 2 al profesor.	02, 07
AUPB-04	Renovar sesión (refresh token)	Emisión de un refresh token de 7 días. Al expirar el token de acceso, el cliente lo renueva sin reautenticar. Modelarlo como caso propio (subfunción), reutilizable por los casos de autenticación. Al implementarlo, la vida del token de acceso puede volver a 15 minutos.	02, 07
AUPB-05	Cerrar sesión con invalidación	Al cerrar sesión se invalida el refresh token de esa sesión, sin afectar otros dispositivos. Depende del AUPB-04.	02, 07

ID	Funcionalidad	Descripción	Casos
AUPB-06	Límite de códigos por IP y contra abuso	El límite por email ya está en el MVP (AURN-04). Agregar un límite por dirección IP y por aplicación, para evitar el envío masivo de correos a muchas direcciones distintas.	01, 05, 10, 11
AUPB-09	Desactivar y reactivar aplicación	Una aplicación inactiva rechaza toda petición hecha con sus credenciales, y conserva roles, permisos y usuarios.	03
AUPB-10	Límite de aplicaciones por organización	Máximo de 5 por organización. Implementarlo junto con la eliminación de aplicaciones (AU-CU-03), para poder liberar lugares.	03
AUPB-11	URL de la aplicación	Dato opcional que hoy ninguna funcionalidad usa. Tendría sentido si se restringen orígenes permitidos o se agregan redirecciones.	03
AUPB-12	Log de auditoría (transversal)	Registrar quién, qué y cuándo en los cambios de roles, permisos y demás casos.	04
AUPB-13	Datos adicionales de perfil y organización	Teléfono del administrador, con validación de prefijo de país y formato estándar, y rubro de la organización, posiblemente de una lista predefinida y útil para filtrar organizaciones.	01
AUPB-14	Identidad compartida entre aplicaciones de una organización	Un mismo usuario, con una sola contraseña, pertenece a varias aplicaciones de su organización. Hay que definir qué pasa al registrar un email ya existente en otra aplicación de la organización, y cómo afectan el cambio de contraseña y la baja.	05
AUPB-15	Búsqueda y filtro en la lista de usuarios	Buscar por nombre o email y filtrar por rol. El filtro por rol facilita eliminar roles, porque muestra quién todavía los tiene. Primera mejora recomendada si sobra tiempo.	06
AUPB-16	Historial de actividad del usuario	Últimos logins y acciones de cada usuario. Depende del log de auditoría (AUPB-12) y de registrar los logins.	06
AUPB-17	Baja lógica de usuarios	Marcar al usuario como eliminado en lugar de borrarlo, conservando su identificador. Requiere decidir cómo se reactiva y cómo se libera el email en el AU-CU-05.	06
AUPB-18	Revocar el acceso de un usuario eliminado	Al eliminar un usuario, invalidar sus sesiones activas en lugar de esperar a que venza el token. En el MVP se mitiga con el AU-CU-09. Depende de los AUPB-04 y 05.	07
AUPB-19	Validar token en Authly	El Sistema Externo envía un token y Authly verifica firma, vencimiento y que el usuario siga existiendo. Alternativa a la validación local; resuelve en gran parte el AUPB-18.	08
AUPB-20	Rotación de claves y formato JWKS	Publicar varias claves con identificador, para cambiarlas sin invalidar todos los tokens de golpe.	08

ID	Funcionalidad	Descripción	Casos
AUPB-21	Consultar todos los permisos de un usuario	Devolver la lista completa de permisos para que el Sistema Externo los guarde en caché y reduzca las llamadas. Incluye consultas en lote.	09
AUPB-22	Cambiar contraseña conociendo la actual	Caso propio, de nivel Objetivo de usuario, para administradores y para usuarios de aplicación (por API). Es distinto de recuperar la contraseña: el actor tiene sesión y se identifica con la contraseña actual.	10, 11
AUPB-23	Invalidar sesiones al cambiar la contraseña	Al completar la recuperación, cerrar las sesiones activas de la cuenta. Depende de los AUPB-04 y 05.	10, 11
AUPB-24	Notificar el cambio de contraseña	Enviar un email avisando que la contraseña fue cambiada.	10, 11
AUPB-25	Autenticarse como superadministrador	Subfunción con cuentas creadas por el equipo de Authly fuera del sistema, sin registro ni recuperación de contraseña, con acceso y token propios y una sesión más corta (1 hora, tentativo). Incluye gestionar esas cuentas (crear, dar de baja y cambiar la contraseña). Si entra, actualiza el AURN-06, el AURN-09 y los casos 07 y 08. Depende del AUPB-26. Borrador analizado, fuera del MVP.	—
AUPB-26	Administrar organizaciones	Supervisión y gobernanza de organizaciones por parte del equipo de Authly. Sin analizar. La priorización original dice que puede resolverse a mano en la base (sin analizar, fuera del MVP).	01
AUPB-27	Código de recuperación más largo	Por ejemplo, 8 caracteres alfanuméricos en los casos 10 y 11. Con tanto espacio de combinaciones, los topes por email dejan de ser necesarios para frenar la adivinación y el límite puede pasar a ser por dirección IP (AUPB-06), lo que elimina la posibilidad de que un tercero bloquee la recuperación de otra persona. Alternativas evaluadas y no elegidas para el MVP: reusar el código pendiente en lugar de emitir uno nuevo, y atar los intentos a un identificador de solicitud.	10, 11